TWAGIRUMUKIZA

人工智能在 SOC 告警分诊中的作用：IT 卫生、零信任与工具碎片化的调节效应

Innocent Twagirumukiza · 2026 年 10 月



每一条线代表一条告警，只有少数是真正的信号。

摘要

人工智能（AI）对安全运营中心（SOC）告警分诊的影响，取决于其所部署环境的质量。本文提出一个概念框架来检验这一论点。研究问题为：IT 卫生（信息技术卫生）的成熟度、零信任（Zero Trust）实施的一致性以及工具碎片化的程度，是否以及如何改变 AI 相对于传统分诊在检测质量和调查成本上的效应。

该框架区分了信息量与信息噪声。它将 AI 的使用视为核心变量，将上述三个因素视为调节变量，将告警数量和规则配置复杂度视为控制变量。文章提出四项研究命题，每项均给出预期方向及其证伪标准。本文提出一个三阶段的验证方案：可复现的针对性综述、探索性定性研究，以及辅以已标注告警受控回放的多层次分析。

本文不报告任何实证结果。其目的是提供一个可检验的基础，以判断在何种条件下 AI 能够真正降低信息噪声，而不是将既有缺陷自动化。

关键词： SOC；告警分诊；信息噪声；人工智能；IT 卫生；零信任；工具碎片化；调节效应；人类决策。

1. 引言

安全运营中心（SOC）集中承担监控、检测、分析和事件响应工作。它们依托安全事件管理、终端检测、威胁情报和响应编排等解决方案。云环境的增多、数字身份的普及以及遥测数据来源的增长，使需要处理的数据量不断增加，而各组织则堆叠专用工具，以覆盖日益扩大的范围。

文献描述了这一状况对人的影响。Tariq 等（2025）梳理了 SOC 中告警疲劳的研究现状。Alahmadi 等（2022）与 Kokulu 等（2019）基于对分析师的访谈，报告了与告警相关性以及工具、流程和人员之间匹配度有关的困难。Vielberth 等（2020）对 SOC 及其尚未解决的挑战进行了系统研究。Ofte 与 Katsikas（2023）考察了操作人员的态势感知。

面对这些困难，AI 越来越多地被视为告警优先级排序、关联和摘要的杠杆。为此，Chhetri 等（2024）研究了分析师与 AI 之间的协作。但 AI 被嵌入的是一个已经成型的环境，其中有既定的检测规则、工具和安全实践，没有任何理由认为其贡献在不同 SOC 之间是相同的。

1.1 拟填补的研究空白

上述研究大多考察告警负荷、人机协作或态势感知。AI 的效应与技术和组织环境质量之间的关联，则较少被形式化。本文的工作假设是：这一空白确实存在，且意义重大；第 5 节所述的针对性综述须在投稿前对此予以证实或证否。

分诊 AI 需要消费上下文：资产标识、资产所有者、账户历史、补丁状态、终端安全态势，以及来自多个工具的日志。如果这些上下文不完整、不一致或分散，AI 可能运行得更快，却未必决策得更好。反之，受控良好的环境则可能使 AI 产生真实的收益。因此，上下文并非单纯的混杂变量：它可能决定了我们试图测量的效应。

1.2 研究问题

IT 卫生成熟度、零信任实施的一致性以及工具碎片化程度，如何改变 AI 相对于传统分诊在 SOC 告警分诊中对检测质量和调查成本的效应?

该问题分解为三个子问题：

1. SQ1（卫生）。 当 IT 卫生更为成熟时，AI 相对于传统分诊的优势是否更为显著?
2. SQ2（碎片化）。 当工具碎片化且互操作性较差时，这一优势是否减弱，抑或 AI 反而弥补了这种碎片化?
3. SQ3（零信任）。 对于与身份和访问相关的告警，一致的零信任实施是否会增强 AI 的优势?

两项结果须一并考察：以漏掉威胁为代价换取的时间节省，并不构成改进。

1.3 贡献与结构

本文提供三项内容：一是区别于信息量和告警疲劳的信息噪声功能性定义；二是以 AI 为核心变量、以环境的三项特征为调节变量的调节框架；三是四项可证伪的命题及相应的验证方案。第 2 节回顾文献，第 3 节介绍框架，第 4 节提出命题，第 5 节阐述验证方法，第 6 至 8 节分别为讨论、局限与结论。

2. 文献综述

本综述有意聚焦于支撑该模型的内容。它仍属初步性质：第 5 节计划在投稿前开展可复现的综述。

2.1 告警数量与疲劳

告警疲劳是指，当分析师处理大量相关性较低或难以确定相关性的告警时，可能出现的注意力或警觉性下降（Tariq 等，2025）。告警数量衡量的是负荷，而非工作的难度：两个收到相同数量告警的 SOC，可能因可用上下文、冗余程度和调查程序的不同而面临截然不同的工作量。因此需要区分所采集事件的数量、所生成告警的数量、相关告警的占比、定性的难度以及最终决策的质量。

2.2 分诊中的 AI 与人机协作

AI 可以对告警进行优先级排序、关联事件、概括上下文并自动化重复性任务。Chhetri 等（2024）主张采用这样一种协作：由自动化处理适合的任务，而人类专业能力则留给模糊的案例。然而，关于自动化的研究表明，过度信任和自满是已知的风险（Parasuraman 与 Riley，1997；Parasuraman 与 Manzey，2010）。因此，只有当漏掉相关威胁的风险没有增加时，AI 以更短时间处理更多告警才会改善安全。这一保留意见说明，应当将调查成本与检测质量一并测量。现有评估也指向同一方向，但存在局限。一项在某高校 SOC 中针对八

张工单的试验由工具设计者自己开展，报告八例中有七例分诊更快（Banstola 等，2026）。一种多智能体架构在可处置告警上取得了高于简单智能体的 F1，但中位延迟高出三倍以上（Wei 等，2025）。一项针对六种安全编排、自动化与响应（SOAR）工具的用户研究发现效率提高，但工单的准确性和完整性下降（Bridges 等，2023）。一项面向 696 名分析师的混合方法调查表明，自动化会减少监控并提高对其输出的信任，而系统性的核验程序可以缓解这一风险（Tilbury 与 Flowerday，2026）。最后，一项涵盖 87 项告警过滤与分诊研究的综述指出，仅有九项基于真实 SOC 数据或实际部署，已发表的结果应视为上限（Ndichu 等，2026）。

2.3 工具碎片化与上下文丢失

SOC 组合了多种专用技术。这种多样性提高了覆盖面，却可能削弱集成度：同一资产使用不同的标识、告警冗余、需要跨多个界面手动重建上下文。Kokulu 等（2019）基于 18 次访谈，记录了 SOC 中技术、流程与人员之间的错位；所涉 SOC 均没有将其工具整合在一起的统一界面。相关变量并非产品数量，而是互操作性、数据的语义一致性以及组件之间的上下文共享。由许多集成良好的工具构成的环境，在本模型意义上并不碎片化。

2.4 IT 卫生

IT 卫生涵盖维持环境受控的基本实践：资产清单、补丁管理、账户与权限管理、安全配置。ANSSI（2017）提出了相应的措施参考框架。对于 SOC 而言，这些实践决定了一条告警能够多容易地关联到某项资产和责任人，以及基线行为的稳定性。然而，卫生状况的改善可能揭示此前不可见的事件，并暂时增加检测数量；因此预期效应涉及的是告警的可解释性，而非其数量。一项关于 SOC 困难的概念性分析，将缺少持续维护的流程、文档不完整和信息流不足，与可能长达三至六个月的规则调优联系起来（Onwubiko 与 Ouazzane，2019）；这是间接线索，而非测量结果。

2.5 零信任

零信任（Zero Trust）建立在对访问的显式验证、最小权限，以及对每次请求的上下文与风险评估之上（Rose 等，2020）。CISA（2023）的成熟度模型将其实施划分为若干支柱，其中包括身份和终端。相关控制措施产生关于身份、设备和访问条件的信息，这些信息与其他来源相关联后，有助于对访问类告警进行定性。但协调不佳的策略也可能使拒绝次数和上下文切换成倍增加。因此，零信任既不是噪声的内在来源，也不是降低噪声的保证。在本模型中，它的作用仅限于与身份和访问相关的告警，在这类告警中它提供上下文。

2.6 综合与当前依据

下表针对模型的每个要素，列出其假定作用以及本文目前拥有的文献依据程度。它凸显了需要通过针对性综述予以巩固的部分。

要素	模型中的假定作用	当前文献依据
告警疲劳与数量	控制变量	充分（Tariq 等，2025；Alahmadi 等，2022）
人机协作	辅助分诊的框架	部分（Chhetri 等，2024；Parasuraman 与 Manzey，2010；Tilbury 与 Flowerday，2026）；评估主要基于公开数据集（Ndichu 等，2026）
工具碎片化	调节变量	部分，主要为定性研究（Kokulu 等，2019）
IT 卫生	调节变量	有参考框架（ANSSI，2017），有间接线索（Onwubiko 与 Ouazzane，2019），关于其与 SOC 关联的研究较少

要素	模型中的假定作用	当前文献依据
零信任	调节变量，身份与访问告警	有参考框架（Rose 等，2020；CISA，2023），关于其与 SOC 关联的研究较少
这些因素与 AI 之间的交互	贡献的核心	初步探索中未发现相关研究；有待通过针对性综述确立

因此，空白与其说是每个因素各自缺乏文献，不如说是据一次未查询任何学术数据库的初步探索（2026 年 10 月），缺乏一个将它们作为 AI 对分诊效应的调节变量加以整合的框架。

3. 概念框架

3.1 信息噪声的定义

信息噪声是指在特定运营情境下，安全信息中占用分析资源、却未能与其占用成比例地有助于识别、定性或管理相关威胁的那一部分。

这一定义是功能性的。非恶意的告警不一定是噪声：它可能验证某项控制的覆盖范围，或揭示配置错误。噪声需要结合调查的目的、信号的价值以及利用该信号所需的工作量来判断。它有别于信息量（一种数量），也有别于告警疲劳（反复暴露于难以应对的负荷之下可能产生的一种人的后果）。

3.2 模型变量

模型提出的是一个差值问题：AI 是否比传统分诊做得更好或成本更低，且这一差值是否随环境而变化？模型包含一个核心变量、三个调节变量、两项结果以及一组控制变量。下图给出其结构，下表给出操作性定义。

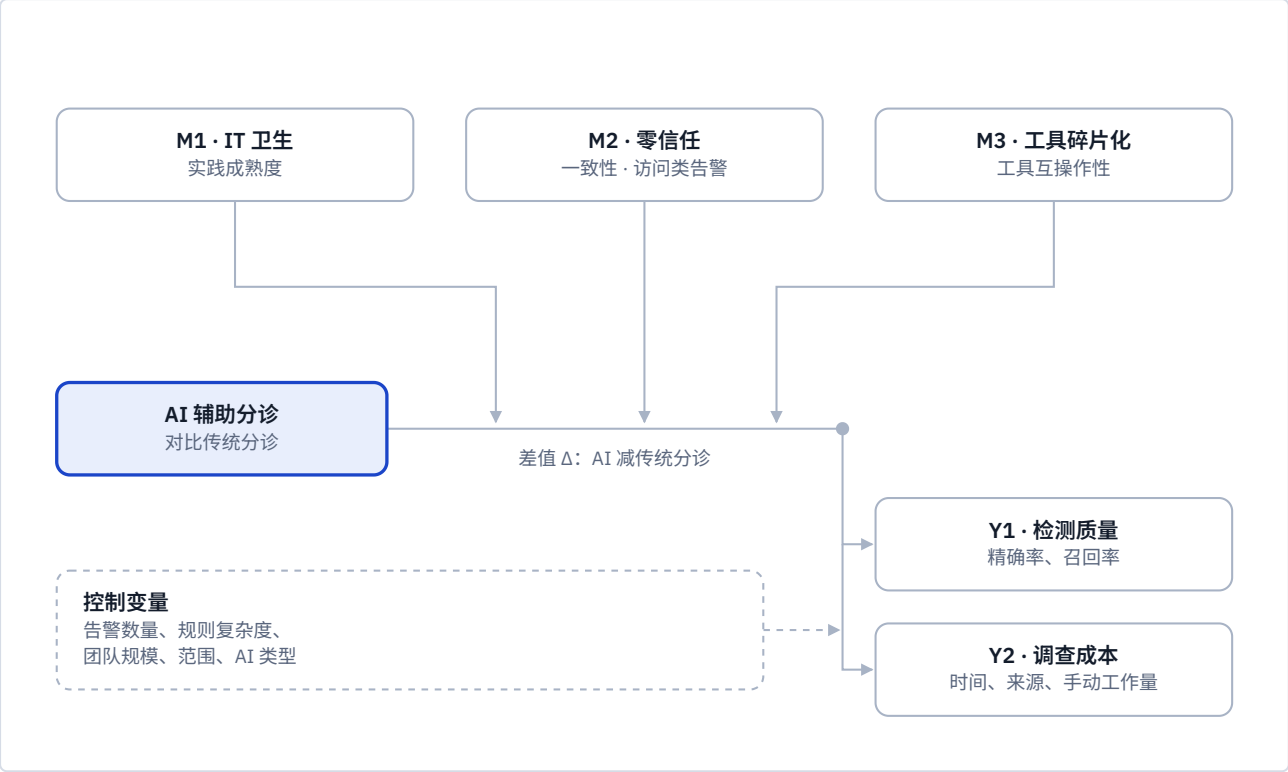


图 1. 调节模型：一个核心变量、三个调节变量、两项结果。

三个调节变量作用于 AI 与传统分诊之间的差值，而非直接作用于结果；控制变量则作用于所比较的两种条件。

角色	变量	操作性定义
核心	AI 辅助分诊	使用 AI 对告警进行优先级排序、关联或摘要，与基于规则和手动程序的传统分诊相比较。以其功能、自动化程度和人工监督来描述。
调节变量 M1	IT 卫生成熟度	资产清单的完整性、补丁合规性、账户与权限的受控程度、配置的维护情况。
调节变量 M2	零信任实施的一致性	访问策略的协调统一，以及身份和终端数据的集成。应用于与身份和访问相关的告警。
调节变量 M3	工具碎片化	实际互操作性较低：同一资产没有共同标识、上下文分散、每条告警需查阅的界面数量。
结果 Y1	检测质量	相关告警上的精确率、召回率和漏报率。
结果 Y2	调查成本	定性所需时间、所查阅的来源数量、每条告警的手动工作量。
控制	数量与配置	告警数量、规则配置复杂度、团队规模与经验、受监控范围、AI 类型。

3.3 对模型的解读

设 Δ 为 AI 辅助分诊与传统分诊之间的性能差值，分别在 Y1 和 Y2 上测量。调节变量是使 Δ 发生变化的变量：AI 的效应并不被假定为恒定，而被假定为有条件的。该模型并不断言 AI 总体上有效或无效；它说明的是其效应在何处、在何种条件下发生变化。

以下三点说明对这一解读加以限定。

1. **成熟度与一致性是两个不同的构念。** 卫生以实践的成熟度来衡量，零信任则以架构及其策略的一致性来衡量。二者将分别加以操作化（第 5 节）。
2. **数量与规则复杂度是控制变量，而非研究对象。** 它们在所比较的两种条件下均影响告警负荷，但本框架并不试图解释其自身的效应。
3. **存在竞争性解读。** 卫生也可能作为改变告警数量的因素发挥作用（直接效应），而最成熟的 SOC 可能正是最先采用 AI 的那些（选择偏差）。第 5 节的方案规定了同一 SOC 内部的比较，以限制后一种风险。

4. 研究命题

以下四项命题是有待检验的理论陈述，而非结果。每项命题均说明预期效应、作用机制以及何种情形将证伪它。“AI 的优势”针对每项结果，指相对于传统分诊而言有利于 AI 的差值：更高的检测质量或更低的调查成本。

P1 基准效应：收益首先体现在成本上

命题陈述。 平均而言，AI 辅助分诊相对于传统分诊降低了调查成本（Y2），但这一降低不足以确立检测质量（Y1）的改善，后者的差值可能为零、为正或为负。

作用机制。 AI 首先通过优先级排序和摘要来提高定性的速度。检测质量取决于排序的准确性以及掩盖重要告警的风险，这是决策辅助系统已知的风险（Parasuraman 与 Manzey，2010）。现有评估将速度的提升与工单准确性和完整性的下降联系在一起（Bridges 等，2023），因此不能从 Y2 的下降推断 Y1 的改善。

证伪条件。 若 AI 下的成本并不更低，或者 Y1 上的优势在所有环境中均一致为正（这将使区分两项结果失去意义），则 P1 被证伪。

P2 IT 卫生：优势随成熟度提高而增大

命题陈述。 在控制告警数量的条件下，IT 卫生成熟度（M1）越高，AI 在 Y1 和 Y2 上的优势越大。

作用机制。 完整的资产清单、受控的账户和稳定的配置，使 AI 能够将每条告警关联到某项资产和责任人，并依托稳定的基线行为。

注意。 更好的卫生状况可能揭示此前不可见的事件，并暂时增加检测数量；因此需要控制告警数量。

证伪条件。 在控制数量之后，AI 的使用与 M1 之间的交互为零或符号相反。

P3 工具碎片化：优势减弱，或 AI 予以弥补

命题陈述。 工具越碎片化、互操作性越差（M3），AI 在 Y1 和 Y2 上的优势越小。

作用机制。 不一致的标识和分散的上下文限制了 AI 关联数据的能力；其输出因而建立在不完整的上下文之上。

竞争性命题。 相反，AI 也可能通过关联分析师否则须逐一查阅的分散来源，来弥补碎片化。在这种情况下，优势在碎片化的环境中会更为显著。这两种解读相互对立，且可通过数据加以区分；对二者作出判别是本研究可能的贡献。

证伪条件。 AI 的使用与 M3 之间的交互为零或为正。正向交互将支持竞争性解读。

P4 零信任：对访问类告警，优势随一致性提高而增大

命题陈述。 对于与身份和访问相关的告警，零信任实施（M2）越一致（即策略得到协调统一，且身份和终端数据已集成），AI 在 Y1 和 Y2 上的优势越大。

作用机制。 零信任控制为定性访问类告警提供了可利用的上下文：终端安全态势、会话风险、所适用的访问决策。

注意。 协调不佳的策略可能使拒绝次数和上下文切换成倍增加，并削弱零信任对分诊的贡献。

证伪条件。 这些告警上不存在交互，或者与访问无关的告警上存在相同幅度的交互。后一种情形表明，所测量的构念反映的是总体成熟度，而非零信任。

综合

命题	因素	对 AI 优势的预期效应	涉及的告警
P1	无（基准效应）	Y2 上有优势；Y1 上的优势尚未确立	全部
P2	M1 IT 卫生	随成熟度提高而增大	全部
P3	M3 工具碎片化	随碎片化加剧而减小（竞争性解读：增大）	全部
P4	M2 零信任	随一致性提高而增大	身份与访问

三个调节变量的叠加（高阶交互）未被表述为命题：它在第 7 节中作为探索性问题处理。

5. 拟议的验证方法

验证按三个阶段依次展开，从最具探索性到最具约束性。一条共同的逻辑贯穿其中：在卫生、零信任和碎片化程度各不相同的情境内部，比较 AI 与传统分诊。

5.1 阶段 0。可复现的针对性综述

将开展一项范围有限的系统综述，依据 PRISMA 2020（Page 等，2021）进行报告，以核实第 1.1 节所提出的空白。它将检索 SOC、告警分诊、AI、IT 卫生、零信任与工具集成之间的交叉领域，并记录数据库、检索式、纳入标准和筛选过程。其结果决定了贡献的最终表述。

5.2 阶段 1。探索性定性研究

将对 SOC 分析师、检测负责人、首席信息安全官（CISO）以及工具集成专家开展半结构化访谈。建议的目标为在 4 至 6 个不同的 SOC（内部、服务提供商、公共部门和私营部门）中进行约 12 至 20 次访谈，直至达到主题饱和。访谈将核实调节变量是否对应于真实的机制、操作性定义是否可操作，并收集 AI 帮助或妨碍分诊的案例示例。

5.3 阶段 2。多层次分析与受控回放

多层次分析。 告警（第 1 层）嵌套于 SOC 或客户范围（第 2 层）之中。调节变量 M1、M2 和 M3 在第 2 层测量；在可能的情况下，AI 的使用在同一 SOC 内部发生变化（部署前后、使用与不使用 AI 的处理队列）。估计包含第 1 层与第 2 层之间交互项的混合效应模型（Raudenbush 与 Bryk，2002；Hayes，2018）。第 2 层交

互的统计功效取决于 SOC 或范围的数量，而非告警的数量。如果该样本量不足以估计三个交互，研究将只保留两个调节变量；而托管服务提供商同时监管多个成熟度水平不同的客户，构成了一个值得探索的自然变异来源。

受控回放。 由专家标注的告警数据集作为基准真值。分析师在有或无 AI 辅助的条件下对其进行处理，并改变所提供上下文的质量（资产清单完整或降级、标识共用与否、身份数据是否集成）。这一操纵使我们能够逼近调节变量对 AI 优势的因果效应，而仅凭生产数据无法确立这一点。注入的场景（例如来自攻击模拟演练的场景）补充了该设计，用以估计召回率，而召回率在生产环境中是不可观测的。根据 Ndichu 等（2026），目前没有公开数据集同时包含真实分析师的判定、调查元数据和纵向上下文；因此回放数据集需要自行构建，或与合作 SOC 协商获取。

基于 GUIDE 的探索性校准。 公开数据集 GUIDE（Freitas 等，2024）将 SOC 告警与分析师的判定（真阳性、良性阳性、假阳性）关联起来，但不包含 M1、M2、M3 的任何测量，也不包含调查成本：因此它无法检验 P2 至 P4。对来自 480 个组织、约 1750 起事件的摘录所作的探索性检查表明，判定在组织层面高度聚集（组内相关系数约为 0.7，基于至少有两起事件的组织估计，不确定性较大）。这一数值支持采用多层次分析，同时提醒我们，判定既反映环境，也反映各 SOC 的评级习惯，仅凭这些数据无法将二者区分。它还表明，决定本研究统计功效的，是组织数量，而非告警数量。

5.4 指标的操作化

五条规则适用于所有指标。指标在数据收集之前确定。调节变量（M1 至 M3）在 SOC 或监控范围层面测量，结果变量（Y1、Y2）在告警层面测量。任何调节变量都不由 AI 的输出或告警数量计算得出，以避免循环论证。每个指标至少依据两个独立来源（例如申报的资产清单与观测到的资产清单）。可靠性通过审计中的评分者一致性（Cohen 的 kappa，Cohen，1960）和对权重的敏感性分析来检验。

M1. IT 卫生成熟度。 卫生被作为形成性指数来测量（Diamantopoulos 与 Winklhofer，2001）：各组成部分不可互相替代，完整的资产清单无法弥补失控的账户。这些指标衡量的是覆盖率和运营合规率；它们不评估流程的规范化、可重复性或持续改进，而这些是更广义的成熟度模型所包含的内容。这里的“成熟度”指由此测得的运营管控水平。共四个组成部分，在受监控范围内均以 0 到 1 的比例表示：

组成部分	指标	来源
资产清单	观测到的资产（网络、终端代理、目录）中，出现在正式清单并指定了责任人的占比	观测扫描与清单的比对
补丁	已评估资产中，不存在适用于该资产且超过补救期限（由成文政策确定）的 CISA KEV 漏洞的占比	漏洞管理工具、补救政策
账户与权限	综合指标 (R + (1 − U)) / 2，其中 R 为近 90 天内完成复核的特权账户占比，U 为无明确责任人的休眠账户或服务账户占比	目录服务、访问复核
配置	符合基线（例如 CIS 基准）的资产占比	合规工具

计算规则事先确定分母、各项控制的适用性、指标的方向（R 为正向、U 为负向，故取 1 − U）、休眠账户的定义，以及对有责任人的合法服务账户的处理。未评估的资产不被视为合规，并报告扫描覆盖率。KEV 目录只收录已知被利用的漏洞：因此该组成部分衡量的是漏洞管理中有针对性的一个维度，而非整体补丁管理。

主指数取四个组成部分的未加权平均值。这是方法上的选择，而非经验事实，因为它假定各部分权重相等。它辅以“最短板”版本（取最小值），用以检验某一领域的单一弱点会限制整体结果这一假设，但不预先认为它更优，并辅以事先确定的替代权重。选用形成性指数本身并不能验证各组成部分及其聚合方式：其内容效度将在阶段 1 与从业者一起检验。单独的自评得分被排除，因为它往往高估成熟度。测量季度在告警观察窗口开始之前结束；若卫生的效应存在滞后，则另加时间间隔。这既限制了反向因果，也考虑到更好的卫生可能使此前不可见的告警显现出来。

M2. 零信任的一致性。 该构念是访问策略的一致性以及身份与终端数据的整合，而非拥有某些产品。四项指标取自 CISA（2023）模型的身份和设备支柱：由统一策略决策点评估的访问占比；由条件强认证覆盖的应用占比；终端安全态势得到评估并传递的比例；告警记录中自动包含终端态势和会话风险的访问事件占比。相互冲突的策略引擎与规则数量作为一致性的反向指标。M2 须与 M1 区分开来：报告二者的相关性，模型控制其共同方差。

M3. 工具的碎片化，而非多样性。 多样性是工具的数量与种类（D）。碎片化是调查告警时整合上的实际缺失。运行二十五种通过共同标识互联的工具的 SOC 是多样但不碎片化的；只有四种互不相连工具的 SOC 是碎片化但不多样的。因此指标针对的是工具之间的连接，而非数量：

指标	定义
实体解析	告警样本中的资产与身份在所有被查阅的来源中以共同标识被找到的占比
上下文可达性	汇集事先确定的最小上下文（资产、责任人、用户、历史、漏洞、相邻网络活动）所需打开的不同控制台数量，以及获取所需的时延
自动富化	最小上下文要素中无需人工操作就已出现在告警记录里的占比

两项安排保护这一区分。D 单独测量并作为控制变量：M3 的效应必须在多样性不变时仍然成立，D 与 M3 的高度相关将表明该构念被简化为多样性。其次，M3 在没有 AI 的运行方式下测量，因为自行富化告警的 AI 会掩盖碎片化。测量 AI 之前的为基础碎片化，测量使用 AI 之后的为残余碎片化；二者之差即 P3 所提及的补偿指标。

X. AI 辅助分诊。 按告警或处理队列记录状态（是否接触 AI），并辅以剂量：受辅助的功能（优先级排序、关联、摘要、自动调查）、自动化程度（提出建议或自行决定）以及由 AI 处理的告警占比。分配尽可能受控：并行队列、部署前后对比，或在回放中随机分配。

Y1. 检测质量。 精确率、召回率和漏报率，按告警类型和严重程度报告。真实标准通过专家双重标注确立，分歧经仲裁，目标 kappa 不低于 0.7。生产环境中分析师的判定不作为唯一的真实标准：它们受 AI 本身及各 SOC 做法的影响。召回率依据注入场景估计。

Y2. 调查成本，扣除核验。 AI 节省的时间可能被核验其输出所额外花费的时间抵消。从开启到关闭告警的单一计时能测出结果，却无法区分这两种机制，也无法发现盲目接受，后者会产生很短的时间而没有真正的收益。因此对成本进行分解：T = 收集 + 分析 + 核验 + 决策，再加上下游成本。

指标	定义	所区分的内容
净定性时间	按告警类型的中位时间，对数正态分布	总体结果
收集与分析时间	打开 AI 建议之前的时间，或传统方式下的对应时间	节省的时间

指标	定义	所区分的内容
核验时间	接触 AI 输出之后在原始来源与证据上花费的时间	增加的时间
修正率	被分析师修改或取消的 AI 建议占比	经校准的信任
返工率	7 天内被重新打开或重新升级的告警占比	错误的下游成本
质量调整后的净成本	净时间除以被正确定性的告警占比	表面收益与真实收益

时长取自界面日志的时间戳（打开建议、打开来源、修改、决策），并辅以回放中的实际计时。回放中可加入主观心理负荷（简化版 NASA-TLX，Hart 与 Staveland，1988）。为发现过度依赖，回放集中会注入 AI 的已知错误：如果核验时间下降而这些错误建议被接受，则 Y2 的下降反映的是自动化偏差（Parasuraman 与 Manzey，2010），而非收益。仅净时间下降时称为表面收益；质量调整后的成本下降且返工没有增加时称为净收益。

控制变量。 告警数量、规则复杂度、团队规模与经验、监控范围、AI 类型，以及输入数据的质量（日志记录的完整性与时延）。后者与卫生相关但并不相同：配置得到良好管控的环境仍可能产生不完整的日志，反之亦然。它被单独测量，以免把属于数据质量的部分归于 M1。只有当召回率没有下降时，告警数量或处理时间的减少才会被解读为收益。

5.5 竞争性假设

每个命题至少有一种可由数据裁决的竞争性解释。下表把它们与能够加以区分的设计一一对应。

竞争性假设	它会预测什么	如何区分
H1. 选择：成熟的 SOC 率先采用 AI	M1 与 AI 优势之间的表面关联，在排除采用因素后消失	SOC 内部比较、前后对比、随机分配的回放
H2. 卫生对数量的直接效应	M1 在两种条件下都减少告警数量，而不改变 AI 与传统方式之间的差距	控制数量；区分交互与主效应；按分层在同等数量下比较
H3. 显现：更好的卫生首先增加检出	正在改进的 SOC 中数量暂时偏高	在告警窗口之前测量 M1，跨多个季度的时间序列
H4. 补偿：AI 关联分散的来源（P3 的竞争假设）	AI × M3 交互为正，且残余碎片化低于基础碎片化	交互的符号；基础与残余之差
H5. 是多样性而非碎片化	归因于 M3 的效应在控制工具数量 D 后消失	同时纳入 D 与 M3 的模型；比较系数
H6. 是总体成熟度而非零信任	与访问无关的告警上出现同等大小的 M2 交互	特异性检验（访问类对其他告警）；控制 M1 后的 M2 残差
H7. 表面收益掩盖了核验	净时间下降，同时返工上升或接受错误建议	分解 Y2、返工率、注入错误
H8. 新奇与观察效应	部署初期或回放中短暂的优势	连续数周重复测量，回放与生产数据对比

5.6 证伪标准

每个命题设三种结论：获得支持、被证伪或无定论。这一区分是必要的，因为 SOC 的数量限制了第二层的统计功效：不显著的交互并不能证伪任何命题。只有当效应的 95% 置信区间完全落在收集前确定的等效区间内（等效性检验，Lakens，2017），该区间围绕在阶段 1 与从业者共同确定的最小实际意义差异时，命题才被证伪。例如，定性时间中位数的降幅低于 15% 可能被判定没有运营意义；该数值仅为示例，将在阶段 1 确定。统计功效不足时，结论为“无定论”。

命题	获得支持，如果	被证伪，如果	竞争解读获得支持，如果
P1	AI 下质量调整后的成本（Y2）更低且返工没有增加，Y1 上的差距不同于 Y2 上的差距	Y2 上的净效应与零等效；或 Y1 上的差距在所有情境下与 Y2 上的符号和大小相同	计入核验与返工后 Y2 上的收益消失：降幅只是表面的（H7）
P2	控制数量后，在 SOC 内部比较中 AI × M1 交互为正，且对指数权重稳健	控制数量后交互与零等效或为负	排除采用因素（H1）或控制数量（H2、H3）后交互消失
P3	多样性 D 不变时，AI × M3 交互为负	交互与零等效	交互为正且残余碎片化降低（H4）；或控制 D 后效应消失（H5）
P4	控制 M1 后，访问类告警上的 AI × M2 交互为正，且大于其他告警（三重交互）	访问类告警上没有交互；或与访问无关的告警上有等效交互	交互出现在所有告警上，且控制 M1 后消失（H6）

因此，命题 P2 至 P4 从不孤立地接受检验：每一个在被宣布获得支持之前都要面对它的竞争假设。指标、等效阈值和分析计划将在收集之前存档（预注册）。与命题相矛盾的结果将与证实命题的结果同等报告。

5.7 分析策略

描述性分析将刻画数量、分布以及不同情境之间的差异。混合效应模型将检验 AI 的使用与每个调节变量之间的交互，设置按 SOC 划分的随机效应并纳入控制变量；P4 将仅在身份与访问告警上估计，然后与其他告警进行比较，作为特异性检验。敏感性分析将改变指标的定义，多重比较将予以校正。由于 AI 的部署并非随机，且最成熟的 SOC 可能最先采用它，因此成熟度被显式建模，并优先采用 SOC 内部比较。在数据收集之前，不能预期任何结果。

5.8 伦理与保密

告警数据具有敏感性，可能包含个人数据。研究将要求与各组织签订保密协议、对日志进行匿名化或假名化，并对处理时间使用汇总数据，以避免对分析师个人进行评价。访谈将取得知情同意。

6. 讨论

6.1 理论贡献

该框架将研究问题从数量转向 AI 的条件性价值。它不是问 AI 是否减轻了告警疲劳，而是问在何种情境下它能改善检测并降低调查成本。这一重新表述带来三点后果。

1. **AI 被视为嵌入环境之中的处理能力，而非孤立的解决方案。** 其效应是有条件的，而被检验的正是这种条件性。
2. **生产率的提高并不等于安全性的提高。** 通过同时测量 Y1 和 Y2，该框架避免了对一种缩短处理时间却放过更多威胁的 AI 得出其表现良好的结论。
3. **竞争性解读从一开始就被提出。** 就碎片化而言，P3 及其竞争性命题预测了相反的符号，这使该框架在从业者直觉出现分歧的问题上具有可证伪性。

6.2 对网络安全治理的启示

安全与 SOC 负责人可以从该框架中得到一个诊断框架，供其在投资 AI 层之前使用。所观察到的困难是源于校准不当的规则、不完整的资产清单、失控的账户、无法互操作的工具，还是缺乏程序？如果答案出在环境上，AI 就有可能带来速度的提升而无检测上的收益，并使其所自动化的缺陷更难被发现。

该框架还建议，在数量指标之外补充相关性、上下文、定性成本和决策绩效方面的度量，并将模糊的案例保留给人工监督。它并不反对创新：它试图确定创新在何种条件下能带来可衡量的改进。

6.3 投资的先后次序

如果 P2 和 P4 得到验证，IT 卫生和零信任的一致性就不只是独立的安全目标：它们还提高了检测类 AI 投资的回报。如果 P3 得到支持，工具集成应先于 AI。如果是竞争性命题占上风，AI 则反而可以成为碎片化的短期缓解手段。无论哪种情形，投资决策都宜建立在对情境的诊断之上，而不是仅仅依赖工具的承诺。

7. 局限与展望

7.1 局限

- **稿件性质。** 本文为概念性文章。它不依赖任何原始数据，其命题尚未确立。文献综述是初步的，须由阶段 0 的可复现综述取代。
- **构念效度。** 卫生、零信任一致性和碎片化都是复合构念，其测量取决于情境。所提议的量表受参考框架（ANSSI，2017；CISA，2023）启发，而这些框架并非为测量 AI 效能的调节变量而设计，须加以验证。
- **零信任的适用范围。** 调节变量 M2 仅适用于身份与访问告警。它对其他类别告警的分诊没有任何说明。
- **基准真值。** 精确率和召回率需要关于相关事件的可靠基准。在生产环境中，召回率不可观测，只能依赖注入的场景，而其代表性有限。
- **选择与因果。** AI 的部署并非随机。SOC 内部比较和受控回放限制了偏差，但无法将其消除。
- **AI 的异质性。** 机器学习分类器、关联引擎和基于语言模型的助手，其优势与缺陷各不相同，且演进迅速。AI 类型是一个控制变量，但其结果未必能从一代工具推广到另一代工具。
- **推广性。** 内部 SOC、服务提供商和公共机构在资源和目标上各不相同。比较时必须将此考虑在内。

7.2 展望

- **高阶交互。** 三个调节变量的效应是相互叠加、相互抵消，还是其中一个便已足够？这一问题具有探索性，需要比首次研究更大的样本。
- **时间维度。** 成熟度是不断演进的。纵向研究可以追踪当卫生、零信任或工具集成得到改善时 AI 优势的变化。
- **人的因素。** 人工监督、过度信任和自满对 Y1 的影响，可以作为额外的中介变量或调节变量加以建模。系统性核验程序可缓解监控的下降（Tilbury 与 Flowerday，2026），是此处未纳入的候选调节变量。
- **对手的适应。** 分诊 AI 可能成为攻击目标。将该框架扩展到针对检测的攻击下的稳健性，值得专门研究。

8. 结论

本文提出，将对告警疲劳的分析从数量转向人工智能的条件性价值。它提出了一个明确的问题：IT 卫生、零信任的一致性和工具碎片化是否以及如何改变 AI 对分诊的效应，具体体现在检测质量和调查成本上。

核心命题是：AI 在 SOC 中的运营价值，不仅取决于其自身能力，还取决于其所处环境在配置、集成和上下文化方面的质量。四项可证伪的命题（其中一项使关于碎片化效应的两种解读相互对立）以及一个三阶段方案，使这一命题得以接受检验。

如果它得到验证，那么在增加一层 AI 之前应当提出的问题，就不再仅仅是工具能够做什么，而是环境允许它做什么。如果它被证伪，该框架至少也将厘清 AI 在何种条件下能够不受情境影响而带来可衡量的收益，这同样会是一个有用的结果。

参考文献

Agence nationale de la sécurité des systèmes d'information (ANSSI). (2017). *Guide d'hygiène informatique : renforcer la sécurité de son système d'information en 42 mesures* (version 2.0). ANSSI.

Alahmadi, B. A., Axon, L., & Martinovic, I. (2022). 99% false positives: A qualitative study of SOC analysts' perspectives on security alarms. *Proceedings of the 31st USENIX Security Symposium*. USENIX Association.

Banstola, K., Al Faisal, F., & Ou, X. (2026). Experiences of using agentic AI to fill tooling gaps in a Security Operations Center. *Workshop on Security Operation Center Operations and Construction (WOSOC 2026)*. NDSS Symposium. https://www.ndss-symposium.org/wp-content/uploads/wosoc26-02.pdf

Bridges, R. A., et al. (2023). *Testing SOAR tools in use* (arXiv:2208.06075). https://arxiv.org/abs/2208.06075

Chhetri, M. B., Tariq, S., Singh, R., Jalalvand, F., Paris, C., & Nepal, S. (2024). Towards human-AI teaming to mitigate alert fatigue in Security Operations Centres. *ACM Transactions on Internet Technology, 24*(3), Article 12, 1–22. https://doi.org/10.1145/3670009

Cohen, J. (1960). A coefficient of agreement for nominal scales. *Educational and Psychological Measurement, 20*(1), 37–46.

Cybersecurity and Infrastructure Security Agency (CISA). (n.d.). *Known Exploited Vulnerabilities Catalog*. https://www.cisa.gov/known-exploited-vulnerabilities-catalog

Cybersecurity and Infrastructure Security Agency (CISA). (2023). *Zero Trust Maturity Model, Version 2.0*. CISA.

Diamantopoulos, A., & Winklhofer, H. M. (2001). Index construction with formative indicators: An alternative to scale development. *Journal of Marketing Research, 38*(2), 269–277.

Freitas, S., Kalajdjieski, J., Gharib, A., & McCann, R. (2024). *AI-driven guided response for Security Operation Centers with Microsoft Copilot for Security* (arXiv:2407.09017). https://arxiv.org/abs/2407.09017

Hart, S. G., & Staveland, L. E. (1988). Development of NASA-TLX (Task Load Index): Results of empirical and theoretical research. In P. A. Hancock & N. Meshkati (Eds.), *Human mental workload* (pp. 139–183). North-Holland.

Hayes, A. F. (2018). *Introduction to mediation, moderation, and conditional process analysis: A regression-based approach* (2nd ed.). Guilford Press.

Kokulu, F. B., Soneji, A., Bao, T., Shoshitaishvili, Y., Zhao, Z., Doupé, A., & Ahn, G.-J. (2019). Matched and mismatched SOCs: A qualitative study on Security Operations Center issues. *Proceedings of the 2019 ACM SIGSAC Conference on Computer and Communications Security*. ACM.

Lakens, D. (2017). Equivalence tests: A practical primer for t tests, correlations, and meta-analyses. *Social Psychological and Personality Science, 8*(4), 355–362.

Ndichu, S., Ban, T., Ozawa, S., Takahashi, T., & Inoue, D. (2026). *AI-driven security alert screening and alert fatigue mitigation in Security Operations Centers: A survey* (arXiv:2605.08316). https://arxiv.org/abs/2605.08316

Ofte, H. J., & Katsikas, S. (2023). Understanding situation awareness in SOCs: A systematic literature review. *Computers & Security, 126*, 103069. https://doi.org/10.1016/j.cose.2022.103069

Onwubiko, C., & Ouazzane, K. (2019). Challenges towards building an effective Cyber Security Operations Centre. *International Journal on Cyber Situational Awareness, 4*(1), 11–39.

Page, M. J., McKenzie, J. E., Bossuyt, P. M., Boutron, I., Hoffmann, T. C., Mulrow, C. D., et al. (2021). The PRISMA 2020 statement: An updated guideline for reporting systematic reviews. *BMJ, 372*, n71. https://doi.org/10.1136/bmj.n71

Parasuraman, R., & Manzey, D. H. (2010). Complacency and bias in human use of automation: An attentional integration. *Human Factors, 52*(3), 381–410.

Parasuraman, R., & Riley, V. (1997). Humans and automation: Use, misuse, disuse, abuse. *Human Factors, 39*(2), 230–253.

Raudenbush, S. W., & Bryk, A. S. (2002). *Hierarchical linear models: Applications and data analysis methods* (2nd ed.). Sage.

Rose, S., Borchert, O., Mitchell, S., & Connelly, S. (2020). *Zero Trust Architecture* (NIST Special Publication 800-207). National Institute of Standards and Technology. https://doi.org/10.6028/NIST.SP.800-207

Tariq, S., Baruwal Chhetri, M., Nepal, S., & Paris, C. (2025). Alert fatigue in Security Operations Centres: Research challenges and opportunities. *ACM Computing Surveys, 57*(9), Article 224, 1–38. https://doi.org/10.1145/3723158

Tilbury, J., & Flowerday, S. V. (2026). The vigilance paradox: Automation reliance inside the modern SOC. *Information & Computer Security, 34*(4), 639–662. https://doi.org/10.1108/ICS-08-2025-0318

Vielberth, M., Böhm, F., Fichtinger, I., & Pernul, G. (2020). Security Operations Center: A systematic study and open challenges. *IEEE Access, 8*, 227756–227779.

Wei, B., Tay, Y. S., Liu, H., Pan, J., Luo, K., Zhu, Z., & Jordan, C. (2025). *CORTEX: Collaborative LLM agents for high-stakes alert triage* (arXiv:2510.00311). https://arxiv.org/abs/2510.00311

© 2026 Innocent Twagirumukiza。初步版本，2026 年 10 月。
在线发布